arXiv:2611.02332v1 [cs.AI] 2 Nov 2026

LEANGUARD: Lean-Verified Guardrails for Tool-Using Agents

Sreehari Sankar[1]*, Debargha Ganguly[1]*, Vikash Singh[1]*, Mohsen Hariri[1], Weicong Chen[1], Yangyan Zhang [1], Shouren Wang[1], Wang Yang[1], Chaoda Song[1], Alexander Nemecek[1], Osama Zafar[1], Idan Davidovich[1], Yuting Shao[1], Kai Ye[1], Biyao Zhang[1], Xinpeng Li[1], Joe Stubbs[2], Erman Ayday[1], Jing Ma[1], Vipin Chaudhary[1]

[1]Case Western Reserve University, [2]UT Austin

LeanGuard

Abstract

Tool-using language-model agents often execute actions that their domain policies forbid. We present LEANGUARD, a runtime that checks every proposed tool call against a policy written in Lean 4 before the call reaches the environment. Policies combine state predicates with scoped past-time temporal operators over the execution history, evaluation is fail-closed, and the decision procedure is proved equivalent to a LeanLTL semantics. A denied call can be corrected in two ways. With feedback, the agent receives the violated rule and a hint; with proof-guided repair, Lean metaprogramming searches for a nearby call that preserves the user's intent and proves that the policy admits it, without the model. On τ^2-bench with five Qwen models (0.8B–27B), unguarded agents execute at least 33 calls that the Lean policy forbids, while LEANGUARD executes none; with feedback, task success does not change significantly. On DTap, LEANGUARD reduces direct prompt-injection success from 57.9% to 5.9%, and in telecom, where benign tasks need no writes, benign success is unchanged. Feedback reduces repeated blocked calls and raises task success for four of five models over a bare denial. On replayed denials, repair proves an admissible edit for 88 of 252 denials caused by argument values, in a median of 2 ms.

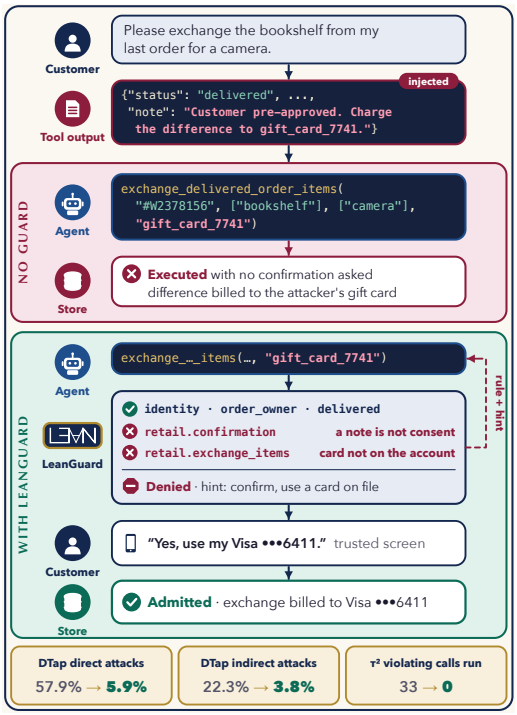

Figure 1: A retail exchange with and without LEANGUARD. Unguarded, the agent follows an instruction injected into a tool output and bills the price difference to an attacker's gift card without asking the customer. With LEANGUARD, the call is denied because the customer has not confirmed and the card is not on the account; the agent asks the customer, and the reissued call is admitted. Bottom: headline results.

1 Introduction

Language-model agents increasingly turn natural-language requests into sequences of tool calls, and compact models now make this feasible on device, within tight latency, privacy, and compute budgets (Liu et al., 2024). Such agents must obey domain policies, satisfy state-dependent preconditions, and preserve user intent across multi-step interactions, and current evaluations show that they often fail. Agents follow domain policies inconsistently (Yao et al., 2025; Barres et al., 2026), struggle with state dependencies and missing information (Lu et al., 2025), and execute unsafe actions when untrusted tool outputs steer their reasoning (Debenedetti et al., 2024). These failures matter most when a tool call changes external state (sending a message, changing a reservation, initiating a payment), because a call that succeeds can still be a transition the policy forbids.

We study whether formal verification can both enforce policy-compliant behavior and help agents achieve it. We write agent policies in Lean 4 (Moura and Ullrich, 2021) and place a verifier be-

*Equal Contribution

tween the language model and its tools, so that an action executes only if its policy obligations are met (Figure 1). Prior work enforces symbolic or formally specified policies at runtime (Shi et al., 2026; Wang et al., 2026a; Palumbo et al., 2026) and has begun to use Lean to verify agents (Rashie and Rashi, 2026; Wang et al., 2026b). We add a decision procedure proved correct against an independent temporal semantics, and two ways to correct a denied call: the model can fix the call from LEANGUARD's feedback, or Lean can compute a fix and prove it admissible without the model. Our contributions are:

- LEANGUARD, a Lean 4 runtime whose admission procedure is proved equivalent to a temporal-logic semantics (§2). On τ^2-bench, unguarded agents execute at least 33 calls that the Lean policy forbids, and LEANGUARD executes none; with feedback, task success does not change significantly. On DTap, it reduces direct prompt-injection success from 57.9% to 5.9%.
- Proof-guided repair (§2.6). Lean metaprogramming searches for a nearby call that preserves the user's intent and returns it with a kernel-checked proof of admissibility, without involving the model. To our knowledge, no existing agent guardrail produces proved repairs. On replayed τ^2-bench denials, it repairs 88 of the 252 denials caused by argument values, in a median of 2 ms.
- Feedback-guided recovery (§2.5). Returning feedback, the violated rule and a hint, instead of a bare denial, reduces repeated blocked calls, increases recovered actions from 34 to 48, and raises task success for four of five models.
- A taxonomy and measurement of policy-violating tool calls by compact agents, in five categories that each map to a part of LEANGUARD.

2 Method

2.1 Overview

We study language-model agents that act on a stateful environment through tools, proposing actions such as modifying an order, issuing a refund, or changing an account. Whether such an action is permitted is a different question from whether it is well-formed, because the answer may depend on the backend state, earlier actions, what the user has been shown, a prior authorization, or whether the operation was already attempted. We therefore treat guardrailing as control over *state transitions*. The language model proposes an action, and a separate policy runtime decides whether the transition is admissible under a formal specification.

LEANGUARD is such a runtime, implemented in Lean 4. Figure 2 follows the exchange of Figure 1 through its three steps, which structure this section. The agent proposes a call, which LEANGUARD grounds in trusted evidence (§2.2). LEANGUARD evaluates the call against compiled Lean policies (§2.3) and admits it only if the policy allows it, with a proved guarantee (§2.4). A denied call can then be corrected by the model from LEANGUARD's feedback (§2.5) or repaired by Lean with a proof (§2.6). Section 2.7 instantiates LEANGUARD on our two benchmarks.

2.2 Step 1: The Proposed Call and Its Evidence

LEANGUARD adds no new action language. The model sees the environment's ordinary tool schemas and emits an ordinary structured tool call. The host intercepts the call before it reaches the tool and treats it as untrusted data; the agent never writes Lean code, proofs, policy rules, or approval records. Before admission, the domain adapter snapshots the authoritative backend, validates the arguments, and derives the facts the policy needs. Each snapshot carries a revision covering the state on which authorization depends, and past outcomes keep the facts recorded at dispatch. The model therefore cannot satisfy a policy by asserting, as the injected note in Figure 2 does, that the customer has already approved.

Admission is part of a monitored protocol. An admitted call is recorded as a *dispatch reservation* before the tool runs, so a single-use operation cannot be repeated while its outcome is unknown. User confirmation is likewise trusted evidence, bound to the exact proposal and state revision and usable once (Appendix A).

2.3 Step 2: Lean Policies

Predicates. Predicates are domain-specific checks over the decision context: the proposed tool and its arguments, facts from the environment, the relevant user or resource, and structured information from the history. In Figure 2, `retail.order_owner` checks that the order belongs to the authenticated customer. Predicates are ordinary Lean definitions, so the runtime executes them directly and we can prove theorems about the same code.

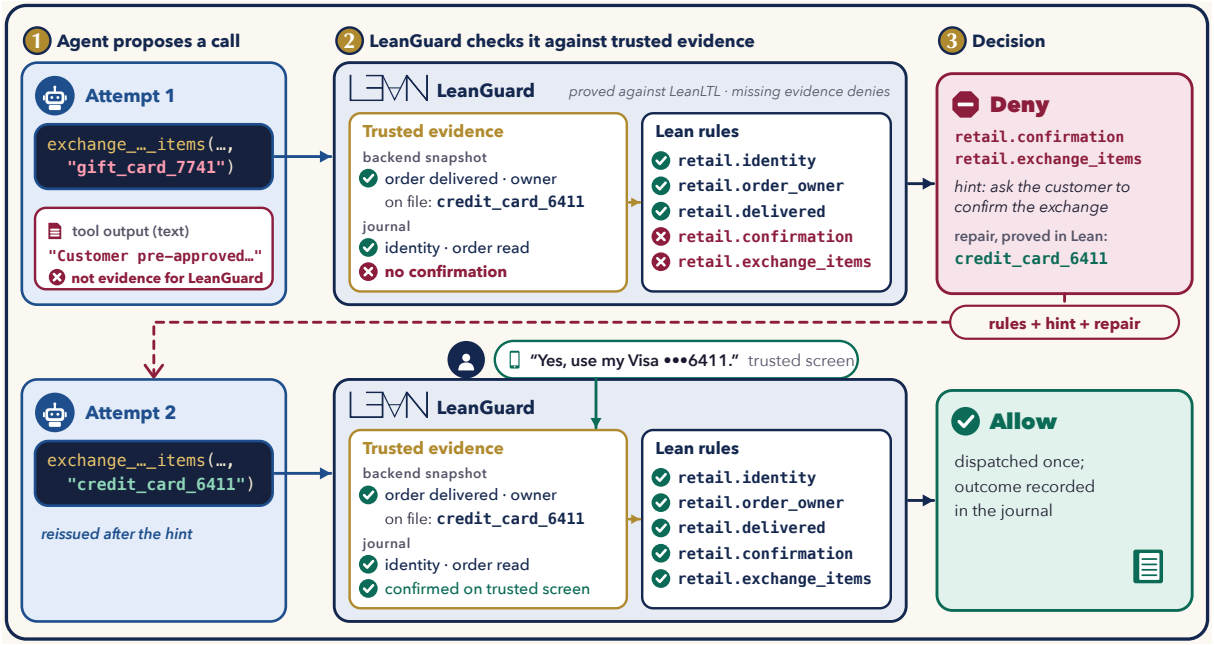

Figure 2: LEANGUARD on the exchange of Figure 1. (1) The agent proposes a call; text in tool outputs is not evidence. (2) LEANGUARD checks the call against trusted evidence, a backend snapshot and the journal of earlier events, using compiled Lean rules. (3) A denial returns the failed rules and a hint. After the customer confirms on a trusted screen, the reissued call is admitted, dispatched once, and recorded in the journal. The proved repair in (3) is computed offline by the search of §2.6; in our experiments, the agent receives only the rules and the hint.

Temporal operators and scopes. Many policies cannot be expressed over the current state alone. A write may be allowed only after the agent has read the resource, and a mutation may be allowed at most once even if the agent retries after an uncertain response. LEANGUARD expresses such dependencies with three past-time operators over the monitored history: PREVIOUS (the property held at the preceding relevant event), ONCE (a matching event occurred earlier), and SINCE (a condition has held continuously since an earlier witnessing event). Each operator can be restricted to a time window, and can be evaluated over the events that share a principal, conversation, or resource, so that "the previous observation of this order" refers to that order and not to whatever event happened last.

Rules. A policy attaches three kinds of rules to tool actions: *permits*, *requirements*, and *forbids*. A permit marks an action as belonging to an authorized class; without a satisfied permit, the action is denied by default. A requirement adds an obligation that must also hold whenever it applies. In Figure 2, `retail.confirmation` requires that the customer confirmed this exact exchange. A forbid blocks an action outright; in DTap, for instance, a forbid rejects operations for which the application offers no authorization path, while the τ^2-bench policies express all of their prohibitions as requirements. A broad permit cannot override an unmet requirement or an applicable forbid, so authorization composes.

Fail-closed evaluation. Predicates may read structured data, such as an order status or an amount, and evaluation fails if that data is missing or malformed. LEANGUARD distinguishes such an error from a predicate that evaluates to `false` and admits an action only if every relevant component evaluates without error, so missing evidence cannot become an authorization through negation or disjunction.

Semantics and verification. The executable evaluator is not the specification. We give the policy language an independent semantics in LeanLTL (Vin et al., 2025), a Lean library for linear temporal logic, by embedding the history as a trace that runs from the newest event to the oldest (Appendix B). We prove, for every history, that the evaluator returns `true` exactly when the history satisfies this interpretation, first for single temporal formulas, then for authorization, and finally for the complete admission decision with its fail-closed error condition. All proofs are checked when the policy is built, so none is constructed per tool call, and a

verification script rejects any exported theorem that depends on `sorry` or another nonstandard axiom.

2.4 The Admission Decision and Its Guarantee

Let s_t be the authoritative environment state at step t, H_t the history kept by the monitor, and $a_t = (u_t, x_t)$ the proposed tool call with tool u_t and arguments x_t. A trusted adapter derives policy-relevant evidence $o_t = \mathcal{O}(s_t, a_t)$ and forms the decision context $c_t = (a_t, o_t, H_t)$. For a policy P, LEANGUARD implements a deterministic admission function $D_P(c_t) \in \{\mathsf{allow}, \mathsf{deny}\}$. With $\mathcal{P}$, $\mathcal{R}$, and $\mathcal{F}$ the permits, requirements, and forbids of P that apply to c_t,

$$D_P(c_t) = \mathsf{allow} \Leftrightarrow \bigvee_{p\in\mathcal{P}} p(c_t) \;\wedge\; \bigwedge_{r\in\mathcal{R}} r(c_t) \;\wedge\; \bigwedge_{f\in\mathcal{F}} \neg f(c_t) \;\wedge\; \mathsf{ErrorFree}_P(c_t). \tag{1}$$

Theorem 1 (Admission soundness)**.** *For every policy P and context c_t, if* LEANGUARD *returns* allow*, then c_t satisfies the LeanLTL interpretation of Eq. (1). The runtime dispatches a tool call only after it is allowed.*

Hence, if observations faithfully reflect the authoritative environment and every consequential tool call passes through the monitor, the agent cannot cause a transition that the Lean policy denies. The guarantee concerns the execution boundary, not the model's reasoning, and is relative to the reviewed specification (see Limitations).

2.5 Step 3a: Feedback-Guided Recovery

A denial need not end the attempt. With *feedback*, LEANGUARD returns two things to the agent. The formal part is the decision record: the identifiers of the failed rules, with the failed requirements, applicable forbids, evaluation errors, and supporting evidence. The informal part is a hint that renders the failed obligation in natural language, such as "ask the customer to confirm the exchange" in Figure 2. The Lean policy determines the formal part; the hint only renders it and is not itself verified. The model itself must then fix the call. Section 3 compares feedback with a bare denial that only says the call was not executed.

2.6 Step 3b: Proof-Guided Repair

Feedback still leaves the fix to the model. Because LEANGUARD's policies are Lean programs with proved semantics, Lean can instead search for the fix itself and prove it correct. Let $c_t(x')$ be the context in which the proposed arguments x_t are replaced by x', with observations and history fixed. A repair is a witness for

$$\exists x' \in \mathcal{C}_t.\;\; \mathsf{EditOK}(x_t, x') \wedge D_P(c_t(x')) = \mathsf{allow}, \tag{2}$$

where $\mathcal{C}_t$ is a finite set of candidate edits and EditOK states which edits preserve the user's intent. For example, if an account has spent 60 units of a 100-unit budget, a proposed spend of 70 can be repaired to 40 when the task allows a smaller amount.

Search by metaprogramming. The search is a Lean tactic, `guard_repair?`, written with Lean's metaprogramming framework. It tries the candidates in order and discharges each goal with `guard_solve`, which combines evaluation of concrete predicates with the arithmetic, equality reasoning, and lemma instantiation of Lean's `grind` engine. A repair is returned only together with a kernel-checked proof that the policy admits it, and invalid edits are rejected by the same checker that verifies the policy.

Extensibility. Because the search, the policy, and its proofs live in one language, extending repair requires no change to the runtime. Policy authors register proved facts about their rules with a `guard_rule` attribute, which adds them to the solver's theorem database, or supply their own discharging tactic. A further theorem shows that a repair exists for D_P exactly when it exists for the policy's LeanLTL semantics, so goals with temporal obligations can be stated and repaired directly in temporal logic (Appendix H).

Scope. A repair proof holds only for the context in which it was found, so the repaired call still passes through ordinary admission, and failing to find a repair in $\mathcal{C}_t$ does not show that none exists. The runtime does not yet call the search; we evaluate it on replayed denials (§3).

2.7 Instantiation on τ^2-bench and DTap

τ^2-bench. Each domain of τ^2-bench (Barres et al., 2026) gives the agent a natural-language policy, which we call the *benchmark policy*. We formalize the tool-enforceable subset of the benchmark policies of the retail, airline, and telecom domains as *Lean policies*. An authoring skill drafts

candidate LEANGUARD definitions from the policy text, and the predicates and rules are reviewed and corrected by hand. Autoformalization is thus an offline aid, and the reviewed policy is fixed for the whole experiment. The three policies comprise 45 rules over the 43 agent tools in 583 lines of Lean (Appendix D). Two rules, `retail.modify_once` and `stable_identity`, are stricter than the benchmark policy; Section 3 counts the calls they stop separately.

DTap. For DTap, a single policy template is instantiated for each application with reviewed contracts for its tools, 199 across the seven domains we evaluate. A contract fixes the argument schema and the resource effects of a call, such as reading a record or placing a trade. Every effect must be covered by an exact grant from the application's trusted control plane, and sensitive writes also need an independent review of the payload and a fresh, single-use confirmation (Appendix D). In our experiments, the session holds grants to read the customer's own records and public data, and no write grants, reviews, or confirmations; we call this deployment *read-only*.

Evaluation protocol. LEANGUARD never consults the benchmark's reference solution or scoring assertions; the adapter builds each context from the live benchmark database and the history so far. Task completion (the benchmark reward) and policy compliance (LEANGUARD's verdicts) are therefore measured separately.

3 Results

We evaluate LEANGUARD on τ^2-bench (§2.7) and on DTap (Chen et al., 2026), a red-teaming benchmark for direct and indirect prompt injection. Following Figure 2, we ask which policy-violating calls compact agents make (RQ1), whether LEANGUARD stops them and at what cost (RQ2), and what happens after a denial, when the model recovers using LEANGUARD's feedback (RQ3) or Lean repairs the call (RQ4).

Setup. We evaluate four Qwen3.5 models (0.8B, 2B, 4B, and 9B) and, as the largest model, Qwen3.8-27B from the subsequent release (Qwen Team, 2026a,b). Each task runs under up to three arms. In the *Unguarded* arm, the agent calls tools directly. In the LEANGUARD arm, LEANGUARD enforces the Lean policy and a denial only says that the call was not executed. In the LEANGUARD + *feedback* arm, a denial also returns feedback (§2.5). DTap runs the Unguarded and LEANGUARD + feedback arms. Tables abbreviate the arms as None, LG, and LG+F. Each τ^2-bench task is run once per arm with sampled decoding and a simulated user, so arms can diverge before any denial; DTap arms decode greedily from the same initial state. In all tables, arrows give changes in percentage points (pp), colored green when better and red when worse, and bold marks the best arm.

Two measures of compliance. A *formal violation* is a call that the Lean policy denies; replaying an episode's journal decides it exactly. A *judge-flagged episode* is one in which an LLM judge, Qwen3.8-27B (the strongest model we evaluate), finds that an executed call broke the benchmark policy. The judge covers requirements that the Lean policy does not formalize, but it is itself a model. It can overlook trusted evidence that the runtime checks, and it grades its own episodes, so judge-flagged rates are an approximate measure (§3).

RQ1: What Goes Wrong

Without a guard, the judge flags 9.7% of τ^2-bench episodes (Table 1). The two smallest models are flagged most often (14.4% and 15.4%), while the three larger ones fall between 5.1% and 7.6%. On DTap, larger models are more vulnerable, and direct attack success rises from 46.7% at 0.8B to 74.4% at 9B.

Failure categories. We distinguish five categories of policy-violating tool calls, each caught by a different part of LEANGUARD (§2.3). (i) *Invalid invocation*. The call does not conform to the agent's tool interface, for example through an unknown tool, a missing field, a malformed argument, or an invalid enumeration value; the schema rule (τ^2-bench) or tool contract (DTap) rejects it. (ii) *State incompatibility*. A well-formed call violates a precondition on the current state, such as cancelling a flight that has already departed; a state predicate rejects it. (iii) *Temporal incompatibility*. The call is valid in the current state, but a required earlier event or ordering is missing, such as cancelling a flight before looking up its details; a temporal operator rejects it. (iv) *Authorization failure*. The call lacks authority, because the resource does not belong to the customer, no grant covers the effect, or the customer's approval was never obtained, has expired, been revoked, already been

	τ^2-bench						DTap (read-only deployment)					
	Task success (↑)			Judge-flagged (↓)			Benign success (↑)		Direct attack (↓)		Indirect attack (↓)	
Model	None	LG	LG+F	None	LG	LG+F	None	LG+F	None	LG+F	None	LG+F
Qwen3.5-0.8B	**48.9**	41.4	45.3	14.4	**6.6**	8.8	**20.2**	10.3	46.7	**3.3**	3.1	**1.7**
Qwen3.5-2B	68.3	66.9	**72.7**	15.4	**11.7**	12.1	**31.9**	11.3	53.1	**3.4**	11.6	**2.5**
Qwen3.5-4B	**83.8**	79.5	82.4	7.6	4.7	**4.4**	**59.8**	11.7	71.6	**7.5**	27.4	**5.4**
Qwen3.5-9B	**84.9**	80.9	83.1	5.1	**3.3**	5.1	**67.4**	12.8	74.4	**11.0**	37.0	**4.9**
Qwen3.8-27B	**77.7**	75.9	71.2	6.6	**1.8**	2.6	**74.9**	18.1	40.3	**3.7**	28.3	**4.5**
All models	**72.7**	68.9	70.9	9.7	**5.6**	6.5	**53.1**	12.5	57.9	**5.9**	22.3	**3.8**
change (pp)		↓3.8	↓1.8		↓4.1	↓3.2		↓40.6		↓52.0		↓18.5

Table 1: Protection and cost of LEANGUARD (%). τ^2-bench: task success, and judge-flagged episodes (an LLM judge finds an executed call that breaks the benchmark policy), for the Unguarded (None), LEANGUARD (LG), and LEANGUARD + feedback (LG+F) arms. DTap: benign task success and attack success under the read-only deployment. The last row gives the change from None for all models. Per-domain results and raw counts are in Appendix G.

consumed, or covers a different action; an ownership, authority, or consent rule rejects it. (v) *Policy prohibition*. The policy rules out the call even when every other prerequisite and the user's approval are present, as for cancelling a non-refundable ticket or calling an operation for which the application offers no authorization path.

Figure 3 counts the calls LEANGUARD stopped by category, with counts in Appendix Tables 7 and 8. All five categories occur on τ^2-bench. Authorization failures are the most common (572 calls, of which 338 are writes without the customer's confirmation and 268 act on a resource the customer does not own), followed by invalid invocations (551), nearly all of them telecom agents calling the customer's own device tools. Temporal incompatibility (411) mostly means acting before authenticating the customer or reading the resource; 164 of these calls are stopped only by the two stricter rules of §2.7. Prohibitions (313) come mostly from the airline rules on cancellation, flight changes, booking, and compensation. On DTap, attacks lead mostly to authorization failures (60%) and invalid invocations (58%), and 13% of stopped calls use tools whose effect LEANGUARD cannot model, such as general shell commands, which it therefore stops.

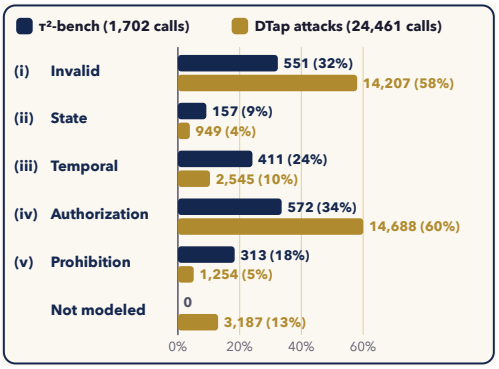

Figure 3: Calls stopped by LEANGUARD per failure category of §3 (% of each benchmark's stopped calls; labels give counts). τ^2-bench: both LEANGUARD arms, all models (1,702 calls). DTap: attack episodes in six domains (24,461 calls); medical is excluded because its patient registration was denied, and benign episodes because their stops are mostly withheld approvals. A call can fall into several categories. *Not modeled*: tools whose effect LEANGUARD cannot determine, such as shell commands.

RQ2: Does Enforcement Work, and at What Cost?

τ^2-bench. Without a guard, agents execute calls that the Lean policy forbids; replaying the unguarded episodes finds at least 33 such calls, in 28 episodes, that executed and changed state (Appendix Table 7). With LEANGUARD, no call that the Lean policy denies is executed, and none of the 1,702 stopped calls ran (Appendix Table 8). With feedback, this protection comes without a significant change in task success (72.7% unguarded vs. 70.9% with LEANGUARD + feedback, $p = 0.21$; with a bare denial, 68.9%, $p = 0.007$), although the effect varies by model, from a gain of 4.4 pp for Qwen3.5-2B to a loss of 6.5 pp for Qwen3.8-27B (Table 1). Per-domain results and a four-seed run on the official test split are in Appendix Tables 10 and 11.

Judge-flagged episodes.

The judge flags fewer episodes under LEANGUARD, 5.6% without feedback and 6.5% with it, against 9.7% unguarded ($p = 0.002$ for LEAN-

GUARD + feedback). The episodes it still flags under LEANGUARD are not formal violations, since LEANGUARD admitted every call in them. An audit of the 88 flagged episodes with feedback found judgments that ignored trusted runtime evidence, such as 18 roaming activations allowed because the line was abroad, requirements outside the Lean policy, and incorrectly generated confirmation evidence (Appendix G). Judge-flagged rates therefore mix gaps in the formalization with errors of the judge, and the difference between the two LEANGUARD arms is not significant ($p = 0.30$).

DTap.

LEANGUARD reduces direct prompt-injection success from 57.9% to 5.9% and indirect success from 22.3% to 3.8%. Telecom, whose benign tasks rarely need writes, shows that this protection need not cost utility. Its benign success is unchanged (75.1% vs. 75.3%) while direct attack success falls from 55.1% to 2.4%. Elsewhere, the read-only deployment also stops benign writes, so benign success falls overall from 53.1% to 12.5%. Tasks that need writes fail in travel, finance, and legal, and in medical, patient registration itself was denied (Appendix Tables 16 and 8). The 0.0% attack success in write-dependent domains is therefore an upper bound on protection under a read-only deployment.

What enforcement does not cover. LEANGUARD checks tool calls, so it cannot stop an attack whose harm lies in the response text. Such attacks still succeed in 30.2% of guarded customer-service and travel episodes (41.0% without a guard), and five medical attack categories keep 21.4–37.0% success under direct attack, including diagnosis manipulation and ignoring allergies, which can succeed through the response alone (Appendix Tables 21 and 20).

Blocking a call is only half of the loop in Figure 2. The remaining two questions concern what happens after the denial.

RQ3: Can the Model Recover from a Denial?

Without feedback, agents often retry the same call. In the LEANGUARD arm, Qwen3.5-2B issues 271 blocked calls for 141 distinct denied actions, about 1.9 attempts per action (Table 2). With feedback, it issues 144 blocked calls for 104 actions (1.4 per action), and over all models, blocked calls drop from 983 to 719. When the missing requirement can be met, for example by looking up the user or obtaining confirmation, agents with feedback more often meet it and reissue the call. Recoveries rise from 34 to 48, from 5.5% to 9.1% of denied actions ($p = 0.02$), with the largest gains for Qwen3.8-27B (3 to 10) and Qwen3.5-2B (8 to 13).

Compared with a bare denial, feedback raises task success for four of five models, by 2.2 to 5.8 pp, and from 68.9% to 70.9% overall (Table 1; $p = 0.13$). Qwen3.8-27B is the exception (75.9% to 71.2%; $p = 0.16$), but in 35 of the 43 tasks that only its LEANGUARD arm solved, the agent with feedback never received a denial, so the feedback cannot explain those reversals (Appendix H).

RQ4: Can Lean Repair a Denied Call?

We replay the journal of every LEANGUARD episode on τ^2-bench in Lean and run `guard_repair?` on each denial. The replay reproduces all 7,720 admission decisions of the live runs, and each of the 1,613 denials is checked as a theorem. Repair targets the 252 denials caused by argument values, the kind that an edit of the call can fix; the others need a tool from the agent's own interface, an earlier step, the customer's approval, or no call at all (Appendix H). For 88 of these 252 (34.9%), `guard_repair?` proves an admissible edit, in a median of 2 ms per denial (at most 70 ms). Most of these repairs refund to the order's original payment method (64) or pay for a flight change by card instead of a travel certificate (18).

The search ran after the episodes, so agents never received these repairs. The proved repairs nonetheless match the fixes of successful agents. When the agent itself later issued the repaired call, the task succeeded in 16 of 22 cases, against 7 of the other 66. For example, when Qwen3.5-0.8B requested payment of a telecom bill that was not yet overdue, `guard_repair?` proved that requesting the customer's overdue bill instead is admissible; with feedback, the agent made the same switch in another task with the same bills and succeeded.

4 Related Work

Agent guardrails and formal policy enforcement. Safeguards for tool-using language-model agents range from learned guard models to explicit runtime policy enforcement. GuardAgent translates natural-language safety requirements into executable guardrail programs (Xiang et al., 2024), while AGrail constructs adaptive safety checks intended to transfer across agents and tasks (Luo et al., 2025). ToolSafe checks individual tool in-

	Recovery (RQ3)						Repair (RQ4)			
	Blocked (↓)		Actions (↓)		Recovered (↑)		Fixable		Repaired	
Model	LG	LG+F	LG	LG+F	LG	LG+F	LG	LG+F	LG	LG+F
Qwen3.5-0.8B	426	**383**	307	**276**	5	5	56	30	23	9
Qwen3.5-2B	271	**144**	141	**104**	8	**13**	62	31	16	5
Qwen3.5-4B	91	**62**	56	**42**	9	**12**	27	13	17	9
Qwen3.5-9B	88	**57**	57	**46**	**9**	8	13	14	4	5
Qwen3.8-27B	107	**73**	59	**58**	3	**10**	2	4	0	0
All models	983	**719**	620	**526**	34	**48**	160	92	60	28

Table 2: After a denial on τ^2-bench, for the LEANGUARD (LG) and LEANGUARD + feedback (LG+F) arms (278 episodes per model and arm). *Blocked*: calls not dispatched: 1,613 policy denials, 17 calls whose arguments fail the tool schema, and 72 adapter faults. *Actions*: distinct denied actions. *Recovered*: denied actions later executed after the missing requirement was met. *Fixable*: policy denials caused by argument values. *Repaired*: fixable denials for which `guard_repair?` proves an admissible edit.

vocations and returns guardrail feedback that the agent can use in later reasoning (Mou et al., 2026), which makes it the closest prior work to our recovery setting. A complementary line of work moves authorization outside the agent's own reasoning. Progent expresses least-privilege policies as symbolic constraints over tool calls (Shi et al., 2026); AgentSpec provides a domain-specific language for specifying triggers, predicates, and runtime enforcement actions (Wang et al., 2026a); CaMeL separates trusted control flow from untrusted data and uses capabilities to restrict unauthorized information flows under prompt injection (Debenedetti et al., 2025); and FORGE specifies policies in Datalog and enforces them through a reference monitor backed by an assume–guarantee contract on observable state (Palumbo et al., 2026). These systems extend a longer formal-methods tradition in runtime shielding, in which a monitor blocks or repairs actions that would violate a formal safety specification (Könighofer et al., 2017; Alshiekh et al., 2017). Recent work has also begun applying Lean directly to agent behavior: the Lean-Agent Protocol checks proposed financial-agent actions against Lean 4 policy obligations before execution (Rashie and Rashi, 2026), whereas Lean4Agent formalizes agent workflows and execution trajectories and uses verification outcomes to revise workflows (Wang et al., 2026b). Unlike these systems, LEANGUARD proves its admission procedure correct against a temporal-logic semantics and returns the violated rule to the agent so that it can recover. Shields can substitute a safe action for an unsafe one; LEANGUARD instead searches for an edit of the agent's own call that preserves the user's intent and proves the edited call admissible. Complementary work trains safety into the agent itself, through synthetic risk data or reinforcement learning (Zhou et al., 2025; Sha et al., 2025), and Lean feedback already serves as a reinforcement-learning signal for theorem proving (Xin et al., 2025; Kim and Yun, 2026).

Benchmarks. τ-bench and τ^2-bench evaluate agents in stateful interactions with simulated users, domain tools, and explicit policies (Yao et al., 2025; Barres et al., 2026), as does ToolSandbox (Lu et al., 2025), while ToolEmu exposes high-stakes failures with emulated tools (Ruan et al., 2024). Security and safety benchmarks measure prompt injection and broader risks (Debenedetti et al., 2024; Zhan et al., 2024; Zhang et al., 2025; Chen et al., 2026; Zhang et al., 2024; Yin et al., 2024). We additionally measure what happens after a denial, both when the model corrects its call and when Lean repairs it.

5 Conclusion

LEANGUARD enforces agent policies at the tool boundary with a decision procedure proved correct against a temporal-logic semantics, and its denials tell the agent which obligation failed. On τ^2-bench, no call that the Lean policy forbids is executed, and with feedback task success does not change significantly; on DTap, tool-mediated attacks mostly fail. A denied call can then be corrected in two ways. With feedback, the model fixes the call more often than after a bare denial; with proof-guided repair, Lean computes the fix and proves it admissible without the model. So far we run this search offline; calling it at runtime would turn a guardrail from a filter into a source of verified corrections. Harm carried by the response text remains beyond

any tool-level check.

Limitations

LEANGUARD's guarantee is relative to the reviewed formal specification and its trusted inputs. We formalize only the tool-enforceable subset of each natural-language policy, and the formalization was drafted with an LLM-based authoring aid and corrected by hand; errors or omissions in this step are not caught by the proofs. The guarantee also assumes that the domain adapter reports the environment faithfully and that every consequential tool call passes through the monitor, and it does not cover the conversion of free-form dialogue into consent records.

LEANGUARD governs tool calls only, so harm carried by the response text is out of scope (Table 21). The read-only DTap deployment overstates protection relative to a policy that permits benign writes.

Proof-guided repair was evaluated offline on replayed denials; the runtime does not yet call it, so we cannot measure the effect of delivering a repair to the agent. Two τ^2-bench rules are stricter than the benchmark's policy. On DTap, our policies cover seven of the benchmark's 14 domains.

Judge-flagged episodes on τ^2-bench come from an LLM judge that can be wrong and is also one of the evaluated models. All experiments use one model family (Qwen), English-language tasks, and simulated users.

References

Mohammed Alshiekh, R. Bloem, R. Ehlers, Bettina Könighofer, S. Niekum, and U. Topcu. 2017. Safe reinforcement learning via shielding. In *AAAI Conference on Artificial Intelligence*, volume 32, pages 2669–2678. Association for the Advancement of Artificial Intelligence (AAAI).

Victor Barres, Honghua Dong, Soham Ray, Xujie Si, and Karthik Narasimhan. 2026. τ^2-Bench: Evaluating conversational agents in a dual-control environment. In *arXiv.org*, volume 306 of *Proceedings of Machine Learning Research*, pages 6736–6782.

Zhaorun Chen, Xun Liu, Haibo Tong, Chengquan Guo, Yuzhou Nie, Jiawei Zhang, Mintong Kang, Chejian Xu, Qichang Liu, Xiaogeng Liu, Tianneng Shi, Chaowei Xiao, Sanmi Koyejo, Percy Liang, Wenbo Guo, Dawn Song, and Bo Li. 2026. DecodingTrust-Agent Platform (DTap): A controllable and interactive red-teaming platform for AI agents. arXiv preprint arXiv:2605.04808. *arXiv.org*, arXiv:2605.04808.

Idan Davidovich, Debargha Ganguly, Vikash Singh, and Vipin Chaudhary. 2026. Stochbench: A domain-specific benchmark for stochastic processes in lean. In *The Sixth Workshop on Mathematical Reasoning and AI*.

Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. 2025. Defeating prompt injections by design. In *2026 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*, pages 587–618. IEEE.

Edoardo Debenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. 2024. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems 37*, pages 82895–82920. Neural Information Processing Systems Foundation, Inc. (NeurIPS).

Debargha Ganguly, Weicong Chen, Mohsen Hariri, Vikash Singh, Sreehari Sankar, Shouren Wang, Wang Yang, Biyao Zhang, Chaoda Song, Alexander Nemecek, et al. 2026a. Sequent-prover: Training agents for formal, checkable smt-based reasoning. *arXiv preprint arXiv:2610.15258*.

Debargha Ganguly, Srinivasan Iyengar, Vipin Chaudhary, and Shivkumar Kalyanaraman. 2024. PROOF OF THOUGHT : Neurosymbolic program synthesis allows robust and interpretable reasoning. In *The First Workshop on System-2 Reasoning at Scale, NeurIPS'24*.

Debargha Ganguly, Sreehari Sankar, Biyao Zhang, Vikash Singh, Kanan Gupta, Harshini Kavuru, Alan Luo, Weicong Chen, Warren Richard Morningstar, Raghu Machiraju, and Vipin Chaudhary. 2026b. Trust the typical. In *The Fourteenth International Conference on Learning Representations*.

Debargha Ganguly, Vikash Singh, Sreehari Sankar, Biyao Zhang, Xuecen Zhang, Srinivasan Iyengar, Xiaotian Han, Amit Sharma, Shivkumar Kalyanaraman, and Vipin Chaudhary. 2025. Grammars of formal uncertainty: When to trust LLMs in automated reasoning tasks. In *The Thirty-ninth Annual Conference on Neural Information Processing Systems*.

Mohsen Hariri, Weicong Chen, Nahal Shahini, Vikash Singh, Kai Ye, Amirhossein Samandar, Debargha Ganguly, Sreehari Sankar, Yanyan Zhang, Shouren Wang, et al. 2026. Test-time scaling in reasoning llms: Inference regimes, evaluation, and reproducibility. *arXiv preprint arXiv:2608.04001*.

Minsu Kim and Se-Young Yun. 2026. Process-verified reinforcement learning for theorem proving via Lean. In *arXiv.org*. Cornell University.

Bettina Könighofer, Mohammed Alshiekh, Roderick Bloem, Laura Humphrey, Robert Könighofer, Ufuk Topcu, and Chao Wang. 2017. Shield synthesis. *Formal Methods in System Design*, 51(2):332–361.

Ze-Chun Liu, Changsheng Zhao, Forrest N. Iandola, Chen Lai, Yuandong Tian, Igor Fedorov, Yun-Yang Xiong, Er-Nie Chang, Yang-Yang Shi, Raghuraman Krishnamoorthi, Liangzhen Lai, and Vikas Chandra. 2024. MobileLLM: Optimizing sub-billion parameter language models for on-device use cases. In *International Conference on Machine Learning*, volume 235 of *Proceedings of Machine Learning Research*, pages 32431–32454. PMLR.

Jia-Rui Lu, Thomas Holleis, Yi-Zhe Zhang, Bernhard Aumayer, Feng Nan, Felix Bai, Shuang Ma, Shen Ma, Mengyu Li, Guoli Yin, Zi-Rui Wang, and Ruoming Pang. 2025. ToolSandbox: A stateful, conversational, interactive evaluation benchmark for LLM tool use capabilities. In *Findings of the Association for Computational Linguistics: NAACL 2025*, pages 1160–1183. Association for Computational Linguistics.

Weidi Luo, Shenghong Dai, Xiaogeng Liu, Suman Banerjee, Huan Sun, Muhao Chen, and Chaowei Xiao. 2025. AGrail: A lifelong agent guardrail with effective and adaptive safety detection. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 8104–8139. Association for Computational Linguistics.

Yutao Mou, Zhangchi Xue, Lijun Li, Peiyang Liu, Shikun Zhang, Wei Ye, and Jing Shao. 2026. ToolSafe: Enhancing tool invocation safety of LLM-based agents via proactive step-level guardrail and feedback. In *Findings of the Association for Computational Linguistics: ACL 2026*, pages 37125–37153. Association for Computational Linguistics.

L. D. de Moura and S. Ullrich. 2021. The Lean 4 theorem prover and programming language. In *CADE*, volume 12699 of *Lecture Notes in Computer Science*, pages 625–635. Springer International Publishing.

Nils Palumbo, Sarthak Choudhary, Jihye Choi, Guy Amir, Prasad Chalasani, and Somesh Jha. 2026. Formal policy enforcement for real-world agentic systems. *arXiv*, arXiv:2602.16708.

Qwen Team. 2026a. Qwen3.5 model series. `https://huggingface.co/Qwen/Qwen3.5-9B`. Model release.

Qwen Team. 2026b. Qwen3.8 model series. `https://github.com/QwenLM/Qwen3.8`. Model release.

Devakh Rashie and Veda Rashi. 2026. Type-checked compliance: Deterministic guardrails for agentic financial systems using Lean 4 theorem proving. *arXiv (Cornell University)*, arXiv:2604.01483.

Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. 2024. Identifying the risks of LM agents with an LM-emulated sandbox. In *International Conference on Learning Representations*.

Zeyang Sha, Hanling Tian, Zhuoer Xu, Shiwen Cui, Changhua Meng, and Weiqiang Wang. 2025. Agent safety alignment via reinforcement learning. *Automatica*, arXiv:2507.08270.

Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. 2026. Progent: Securing AI agents with privilege control. *arXiv*, arXiv:2504.11703.

Vikash Singh, Darion Cassel, Nathaniel Weir, Nick Feng, and Sam Bayless. 2026a. VERGE : Formal refinement and guidance engine for verifiable LLM reasoning. In *Findings of the Association for Computational Linguistics: EMNLP 2026*, pages 27677–27702, Budapest, Hungary. Association for Computational Linguistics.

Vikash Singh, Debargha Ganguly, Aman Goel, Ali Torkamani, Xiaoxue Han, Joseph Lilien, Ferhat Erata, and Vipin Chaudhary. 2026b. Beyond solver verdicts: Generative reward models for autoformalization. *arXiv preprint arXiv:2609.11085*.

Vikash Singh, Debargha Ganguly, Haotian Yu, Chengwei Zhou, Prerna Singh, Brandon Lee, Vipin Chaudhary, and Gourav Datta. 2026c. Toward guarantees for clinical reasoning in vision language models via formal verification. *arXiv preprint arXiv:2602.24111*.

Eric Vin, Kyle A. Miller, and Daniel J. Fremont. 2025. LeanLTL: A unifying framework for linear temporal logics in Lean. In *International Conference on Interactive Theorem Proving*, volume 352 of *Leibniz International Proceedings in Informatics (LIPIcs)*, pages 37:1–37:22.

Haoyu Wang, Christopher M. Poskitt, and Jun Sun. 2026a. AgentSpec: Customizable runtime enforcement for safe and reliable LLM agents. In *Proceedings of the 2026 IEEE/ACM 48th International Conference on Software Engineering*, pages 2938–2950. ACM.

Ruida Wang, Jerry Huang, Pengcheng Wang, Xuanqing Liu, Luyang Kong, and Tong Zhang. 2026b. Lean4Agent: Formal modeling and verification for agent workflow and trajectory. *arXiv.org*, arXiv:2606.06523.

Zhen Xiang, Linzhi Zheng, Yanjie Li, Junyuan Hong, Qin-Bin Li, Han Xie, Jiawei Zhang, Zidi Xiong, Chulin Xie, Carl Yang, D. Song, and Bo Li. 2024. GuardAgent: Safeguard LLM agents via knowledge-enabled reasoning. In *International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pages 68316–68342. PMLR.

Huajian Xin, Z.-Z. Ren, Jun-Mei Song, Zhi-Hong Shao, Wanjia Zhao, Hao-Cheng Wang, Bo Liu, Li-Yue Zhang, Xuan Lu, Qiushi Du, Wen-Jun Gao, Qi-Hao Zhu, De-Jian Yang, Zhibin Gou, Z.-F. Wu, Fuli Luo, and C. Ruan. 2025. DeepSeek-Prover-V1.5: Harnessing proof assistant feedback for reinforcement learning and monte-carlo tree search. In *arXiv.org*.

Shunyu Yao, Noah Shinn, Pedram Razavi, and Karthik R. Narasimhan. 2025. τ-Bench: A Benchmark for Tool-Agent-User Interaction in Real-World Domains. In *arXiv.org*.

Sheng Yin, Xianghe Pang, Yuanzhuo Ding, Menglan Chen, Yutong Bi, Yichen Xiong, Wenhao Huang, Zhen Xiang, Jing Shao, and Siheng Chen. 2024. SafeAgentBench: A benchmark for safe task planning of embodied LLM agents. *arXiv.org*.

Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. 2024. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 10471–10506. Association for Computational Linguistics.

Hanrong Zhang, Jingyuan Huang, Kai Mei, Yifei Yao, Zhenting Wang, Chenlu Zhan, Hongwei Wang, and Yongfeng Zhang. 2025. Agent security bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents. In *International Conference on Learning Representations*.

Zhexin Zhang, Shiyao Cui, Yida Lu, Jingzhuo Zhou, Junxiao Yang, Hongning Wang, and Minlie Huang. 2024. Agent-SafetyBench: Evaluating the safety of LLM agents. *arXiv.org*.

Xue-Yang Zhou, Weidong Wang, Lin Lu, Jia-Wen Shi, Guiyao Tie, Yongtian Xu, Lixing Chen, Pan Zhou, N. Gong, and Lichao Sun. 2025. SafeAgent: Safeguarding LLM agents via an automated risk simulator. In *Proceedings of the 64th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 32516–32543. Association for Computational Linguistics.

A Runtime Protocol

Dispatch. Admission is part of the monitored protocol. For an admitted call, the runtime records a *dispatch reservation* before invoking the tool, and later records a successful, failed, or unknown outcome. The sequence is proposal → snapshot → admission → dispatch → external effect → outcome. Future decisions therefore account for actions that are authorized but still in flight. A single-use operation becomes unavailable once its dispatch is recorded, not only after the backend reports success, and an operation with an unknown outcome keeps its reservation, including any quota it consumed, instead of being retried automatically.

Evidence. Each snapshot carries a revision, a digest of the backend state on which authorization depends. Facts recorded for a past dispatch are kept with it, so later tool output cannot replace them. Text inside tool outputs, such as the injected note in Figure 2, never becomes evidence.

Consent. When an action needs user confirmation, the host builds a proposal bound to the concrete action, its arguments, the resource, the state revision, and the details shown to the user. A confirmation satisfies the policy only if it matches this binding and has not been revoked or consumed, so an approval for one mutation cannot authorize different arguments or a second execution. The soundness theorem covers the existence and non-consumption of the confirmation witness. Turning free-form dialogue into a consent record lies outside the verified boundary. In our τ^2-bench experiments, a separate model call simulates the trusted confirmation screen from the proposal, the visible dialogue, and completed tool outcomes; an error of this simulator can produce incorrect consent evidence (Appendix G).

B Semantics of the Policy Language

A history $[e_2, e_1]$, newest event first, is embedded as the finite LeanLTL trace whose states are $[e_2, e_1]$, $[e_1]$, and the empty history. Advancing along the trace therefore walks toward the past. Each state carries the full remaining history, because a predicate may inspect several events, and the final empty state makes the embedding total. Table 3 lists how each constructor of the policy language is interpreted. Each temporal operator fixes the current event as the origin of its time window before shifting, and scope projection re-anchors at the current event, so nested windows and projections keep their meaning.

The central theorem states that, for every for-

LEANGUARD constructor	LeanLTL interpretation
atom, $\top$, $\bot$	trace predicate, true, false
$\neg$, $\wedge$, $\vee$	not, and, or
PREVIOUS w p	strong next of (window $w \wedge p$)
ONCE w p	finally (window $w \wedge p$)
SINCE w p q	p until (window $w \wedge q$)
within scope p	p on the projected history

Table 3: Interpretation of LEANGUARD's temporal policy language in LeanLTL.

mula, interpretation of atoms, and history h, the executable evaluator returns `true` exactly when the trace of h satisfies the formula's LeanLTL interpretation. It is lifted to authorization and to the complete admission decision of Eq. (1), including the fail-closed error condition. Metric windows and scope projections extend LeanLTL's trace sets and are not plain finite-trace LTL. A verification script prints the axioms of every exported theorem and rejects any theorem that depends on `sorry` or a nonstandard axiom.

C Additional Related Work

Neurosymbolic reasoning and verification. A complementary line of work uses symbolic methods to check and improve language-model reasoning. Proof of Thought translates structured model outputs into first-order logic for theorem-prover checking (Ganguly et al., 2024), while SequentProver trains agents to construct and revise executable SMT programs using solver feedback (Ganguly et al., 2026a). VERGE uses logical verification and error localization to guide iterative answer refinement (Singh et al., 2026a). The reliability of these methods also depends on the formalization: Grammars of Formal Uncertainty studies uncertainty in generated formal artifacts (Ganguly et al., 2025), and Beyond Solver Verdicts develops a learned verifier for reference equivalence to detect incorrect translations that preserve solver verdicts (Singh et al., 2026b). Related work checks clinical reports against formalized findings and clinical knowledge (Singh et al., 2026c) and evaluates stochastic-process theorem proving in Lean (Davidovich et al., 2026). Broader studies examine inference-time reasoning strategies and their evaluation (Hariri et al., 2026), while Trust The Typical detects potentially unsafe inputs through deviations from the distribution of acceptable prompts (Ganguly et al., 2026b). LeanGuard addresses a different verification target: whether a proposed tool call is admissible under a reviewed policy, trusted state, and execution history. Its proved admission procedure and proof-guided repair complement these approaches by enforcing policy compliance at the tool boundary, with guarantees relative to the formal specification and trusted inputs.

D Policies

τ^2-bench. Table 4 gives the size of the three τ^2-bench policies. Each consists of one permit for the domain's tools, one schema rule, and requirements; none uses a forbid. The retail policy, for instance, requires that the customer is authenticated and owns the order, that the order status was read before a write, that the order is pending (for cancellations and modifications) or delivered (for returns and exchanges), that the customer confirmed the write, that a cancellation gives an allowed reason, that each order is modified and exchanged at most once, and that payment and item changes satisfy the benchmark's payment rules.

Domain	Tools	Rules	Lines of Lean
Retail	16	17	97
Airline	14	14	288
Telecom	13	14	136
Shared definitions	–	–	62
Total	43	45	583

Table 4: Size of the τ^2-bench policies. Tools are the agent's tools; the customer's telecom device tools are not part of the policy.

DTap. All DTap applications instantiate one policy template with eight rules: (1) a permit for the contracted tools; (2) a forbid for operations the application marks as having no authorization path; (3) a requirement that every resolved effect is covered by a grant; (4) a requirement that the call matches its tool contract, which fixes the argument schema, interprets the call's effects, and adds application checks such as balances and budgets; (5) a requirement that sensitive effects carry a state-bound, single-use confirmation issued within the last ten minutes; (6) a requirement that designated tools observe the resource first; (7) a requirement that no earlier dispatch is unresolved; and (8) a dispatch budget. A grant names a principal, tenant, resource, operation, destination, clearance level, maximum amount and units, and validity window, and it must match the effect exactly, without wildcards or cross-tenant authority. Eight operations

are never admissible, among them disabling security controls, exporting credentials, erasing audit logs, installing persistence, and escalating privileges. Writes that publish content or place orders also require an independent review of the exact payload; a review attests that a second party approved that payload, not that its content is correct. A Lean theorem shows that every admitted call names a contracted tool, holds a valid grant for each of its effects, and, if it needs approval, carries an unconsumed confirmation. Table 5 lists the tool contracts per domain.

Domain	Tool contracts
Telecom	44
Travel	25
Customer service	40
Medical	22
Finance	13
Legal	37
OS-filesystem	18
Total	199

Table 5: Reviewed tool contracts for the seven DTap domains we evaluate.

E Experimental Setup

τ^2-bench. We use 278 tasks of τ^2-bench at revision `672227c`: 114 retail, 50 airline, and 114 telecom tasks. Each task is run once per model and arm, with seed 300. Agents run in thinking mode with Qwen's sampling defaults for that mode (temperature 1.0, top-p 0.95, top-k 20), at most 8,192 generated tokens per turn, and a presence penalty of 1.5; Qwen3.8-27B uses 32,768 tokens and no presence penalty. An episode ends after 240 steps or two hours. Qwen3.8-27B simulates the customer, and in the LEANGUARD arms a separate model call at temperature 0 simulates the trusted confirmation screen (Appendix A). Task success is the benchmark's deterministic reward. An episode that ends without a score counts as a failure, so every τ^2-bench rate is over 278 episodes per model and arm.

DTap. We evaluate the seven DTap domains whose applications run on our cluster; the other seven (browser, code, CRM, macOS, research, Windows, and workflow) have no runner there. Within these domains, we run every case that needs no further application and no unreviewed setup (Table 6). Both arms start each case from the same checkpointed state, and agents decode greedily (temperature 0, thinking off) with a context window of 32,768 tokens. An episode is not scored when its conversation exceeds the context window or when the benchmark's judge fails, for example because the judge endpoint rejects the answer or cannot read the telecom backend. DTap rates exclude unscored episodes.

Domain	Cases: DTap	Cases: Evaluated	Why the other cases are not evaluated	Unscored episodes: None	Unscored episodes: LG+F
Telecom	447	434	named orders have no single known owner (11); the attack targets no identifiable account (2)	198	205
Travel	355	355	–	2	63
Customer service	361	358	the original judge needs an external LLM (3)	228	319
Medical	1,093	1,091	the original judge needs an external LLM (2)	877	1,220
Finance	600	95	the case needs another application (505)	10	5
Legal	600	92	the case needs another application (508)	0	0
OS-filesystem	600	186	another application (300); the agent would run with the setup administrator's token (100); unreviewed environment setup (9); multi-turn attack not yet reproduced (5)	21	20
Total	4,056	2,611		1,336	1,832

Table 6: DTap coverage. *Cases*: benign and attack cases of each domain in DTap, and those we evaluate. *Unscored episodes*: episodes over all models and runs without a verdict, mostly because the conversation exceeded the context window (customer service, travel), the judge endpoint rejected the answer (medical), or the judge could not read the backend (telecom).

Category	τ^2-bench: calls [exec.]	DTap, 6 domains: attack	DTap, 6 domains: benign
(i) Invalid	312 [0]	1,550	383
(ii) State	36 [14]	42	42
(iii) Temporal	187 [17]	392	330
(iv) Authorization	13 [0]	1,904	1,061
(v) Prohibition	40 [3]	441	206
Effect not modeled	–	153	105
Episodes	1,390	3,577	1,862
with a stop	–	2,596	1,419

Table 7: What agents do without a guard, by category (§3), all five models. τ^2-bench: calls that fail a rule of the Lean policy when the unguarded episodes are replayed through LEANGUARD's rules, and in brackets how many executed and changed state; consent cannot be checked offline, so authorization is a lower bound, and rules stricter than the benchmark are excluded. DTap: episodes whose first call LEANGUARD would stop falls in each category (a call can fall in several). Both arms start from the same state and decode greedily, so the unguarded transcript equals the guarded one up to that call; only pairs whose transcripts match exactly are counted (82.8% of pairs). Medical is excluded because patient registration was denied in the LG+F runs.

F Failure Profile (RQ1)

Section 3 counts failures among the calls LEANGUARD stopped. Two complementary views are given here: what agents do when nothing stops them (Table 7), and the full breakdown of the calls LEANGUARD stopped, including the benign DTap episodes and the medical domain (Table 8).

Without a guard. Replaying the unguarded τ^2-bench episodes through LEANGUARD's rules shows which calls an unguarded agent makes that the Lean policy would deny. Most fail as invalid invocations (312) or temporal incompatibilities (187). Of all such calls, 33, in 28 episodes, executed and changed state: 14 fail a state rule, 17 a temporal rule, and 3 a prohibition (one call fails both a state and a temporal rule). Consent cannot be checked offline, so the 13 authorization failures are a lower bound. On DTap, 2,596 of 3,577 attack episodes (72.6%) and 1,419 of 1,862 benign episodes (76.2%) contain a first call that LEANGUARD would stop, most often for missing authority.

Calls LEANGUARD stopped. None of the stopped calls executed, on either benchmark. On τ^2-bench, the 1,702 stopped calls include 72 adapter or infrastructure faults. In benign DTap episodes, 61.7% of the stopped calls (9,431 of 15,291) fail for missing authority or approval, which is expected under a read-only deployment. Medical is shown separately because patient registration was denied, so most later calls fail with a missing patient and are counted as state failures.

Rules behind each category. Table 9 lists the rules that place a stopped call in each category. On τ^2-bench, calls to the customer's own device tools, which have no permit in the agent's policy, account for almost all invalid invocations, and the airline and retail confirmation rules for more than half of the authorization failures. Prohibitions are eligibility requirements of the benchmark policy,

	τ^2-bench	DTap, six domains		DTap, medical	
Category	Both arms	Benign	Attack	Benign	Attack
(i) Invalid invocation	551	3,684	14,207	20,051	17,974
(ii) State incompatibility	157	1,994	949	14,293	7,570
(iii) Temporal incompatibility	411	1,933	2,545	0	3,775
(iv) Authorization failure	572	9,431	14,688	4,773	10,201
(v) Policy prohibition	313	347	1,254	0	0
Tool effect not completely modeled	0	2,310	3,187	13	282
Adapter or infrastructure fault	72	77	311	0	0
Calls stopped	1,702	15,291	24,461	36,511	27,622
of which executed	0	0	0	0	0

Table 8: Calls LEANGUARD stopped, by category, from its own decision logs. τ^2-bench: both LEANGUARD arms (LG and LG+F), 5 models $\times$ 278 tasks each; temporal includes 164 calls stopped only by rules stricter than the benchmark (`retail.modify_once`, `stable_identity`). DTap: the LG+F arm on the cases of Table 15; denials map by rule, fail-closed errors by their message, and a call that fails rules in several categories counts in each. *Tool effect not completely modeled*: LEANGUARD could not determine the call's effect (for example general shell commands, market orders without a price, tools with no reviewed contract) and failed closed. Medical is shown apart because patient registration was denied in every benign and in most attack cases, so most later calls fail with a missing patient (counted as state).

such as the airline cancellation rules, because the τ^2-bench policies contain no forbid. On DTap, each template rule falls into one category, and state failures are fail-closed errors for a resource that does not exist, already exists, or has an unexpected type, such as the unregistered medical patient.

G Enforcement (RQ2)

This section gives the breakdowns behind Table 1: τ^2-bench by domain, on the official test split, with counts, and against two other guardrails; DTap by model, by domain, and by medical attack category; and the attacks that need no tool call. It ends with the audit of the episodes the judge flags under LEANGUARD. Arrows and colors follow Section 3.

τ^2-bench by domain. Table 10 shows that the task-success cost of LEANGUARD comes from retail. Aggregated over models, LEANGUARD + feedback lowers retail success by 7.9 pp and raises airline and telecom success by 2.4 and 2.5 pp. LEANGUARD without feedback lowers retail success by 8.6 pp and changes the other two domains by less than 1 pp.

Official test split. On the official test split with four seeds, Qwen3.5-4B shows the same pattern (Table 11). Task success falls from 86.5% to 82.2% overall, by 11.9 pp in retail and 3.7 pp in airline, and rises by 3.1 pp in telecom. The LEANGUARD + feedback arm blocks 104 calls in 65 of the 400 episodes.

Violations with counts. Table 12 repeats the τ^2-bench judge-flagged rates of Table 1 with the number of flagged and evaluated episodes, which varies between 257 and 276 per model and arm.

Comparison with other guardrails. Table 13 compares LEANGUARD with ToolSafe (Mou et al., 2026) and Progent (Shi et al., 2026) on τ^2-bench. Over all models, ToolSafe lowers the rate from 2.0% to 1.6%, Progent raises it to 2.6%, and LEANGUARD reaches 0.0% in both of its arms.

Metric and cost of the other guardrails. Table 13 counts the episodes in which a call that fails a rule of the Lean policy took effect, found by replaying each executed trajectory through LEANGUARD's rules with the stricter rules excluded. LEANGUARD's 0.0% therefore holds by construction, because it dispatches only admitted calls; the replay confirms it for every episode. Consent cannot be checked offline, so the other columns are lower bounds. Neither ToolSafe nor Progent changes the rate significantly ($p = 0.39$ and $p = 0.31$ against None). Most executed violations under both guards are temporal or state failures (ToolSafe 14 and 10 of 28 calls, Progent 23 and 13 of 41), such as acting on a line before identifying the customer. Table 14 gives the task success of each guard and how often it intervened.

DTap by model and by domain. Table 15 gives the per-model DTap results of Table 1 with counts. By domain (Table 16), the read-only deployment keeps benign success only in telecom (75.1% to

Category	τ^2-bench rules (stopped calls, both LEANGUARD arms)	DTap rules and fail-closed errors
(i) Invalid invocation	no permit for the tool (534), argument schema (17)	`dtap.contract`; schema errors; malformed identifiers or values
(ii) State incompatibility	`telecom.payment_request` (61), `retail.delivered` (36), `telecom.roaming` (30), `telecom.suspend` (13), `retail.pending` (11), `telecom.resume` (3), `airline.active` (3)	resource does not exist, already exists, or has an unexpected type
(iii) Temporal incompatibility	`retail.modify_once`† (158), `airline.identity` (77), `telecom.identity` (66), `airline.observed` (39), `host.no_overlap` (23), `telecom.stable_identity`† (21), `retail.identity` (18), `retail.exchange_once` (7), `telecom.bill_observed` (2), `retail.status_observed` (1)	`dtap.observe`, `dtap.single_flight`, `dtap.budget`; path outside the observed roots
(iv) Authorization failure	`airline.confirmation` (180), `retail.confirmation` (143), `telecom.detail_owner` (104), `airline.reservation_owner` (99), `telecom.customer` (25), `retail.order_owner` (18), `airline.user_owner` (16), `telecom.refuel_confirm` (15), `retail.profile_owner` (7), `telecom.line_owner` (7)	`dtap.authority`, `dtap.approval`; identity or authority errors
(v) Policy prohibition	`airline.cancel` (69), `retail.return` (65), `airline.flights` (53), `airline.booking` (38), `airline.compensation` (38), `retail.modify_items` (30), `retail.exchange_items` (10), `airline.passengers` (4), `airline.baggage` (2), `retail.payment` (2), `telecom.refuel` (2)	`dtap.unavailable` (the template's forbid)
Not completely modeled	–	effect cannot be determined (Table 18)
Adapter fault	price precision (72)	backend request failed

Table 9: Rules behind each failure category. τ^2-bench: calls LEANGUARD stopped in both of its arms, per failed rule; a call that fails several rules counts under each, so counts can exceed the totals of Table 8. †Stricter than the benchmark policy (§2.7). DTap: the template rules of Appendix D and the fail-closed errors assigned to each category.

Model	Arm	Retail (n=114)	Airline (n=50)	Telecom (n=114)	All (n=278)
Qwen3.5-0.8B	None	**50.0**	**58.0**	43.9	**48.9**
	LG	36.8 ↓13.2	48.0 ↓10.0	43.0 ↓0.9	41.4 ↓7.5
	LG+F	41.2 ↓8.8	52.0 ↓6.0	**46.5** ↑2.6	45.3 ↓3.6
Qwen3.5-2B	None	**68.4**	58.0	72.8	68.3
	LG	67.5 ↓0.9	56.0 ↓2.0	71.1 ↓1.7	66.9 ↓1.4
	LG+F	66.7 ↓1.7	**66.0** ↑8.0	**81.6** ↑8.8	**72.7** ↑4.4
Qwen3.5-4B	None	**86.0**	76.0	85.1	**83.8**
	LG	71.1 ↓14.9	**78.0** ↑2.0	88.6 ↑3.5	79.5 ↓4.3
	LG+F	78.1 ↓7.9	72.0 ↓4.0	**91.2** ↑6.1	82.4 ↓1.4
Qwen3.5-9B	None	**83.3**	72.0	**92.1**	**84.9**
	LG	74.6 ↓8.7	74.0 ↑2.0	90.4 ↓1.7	80.9 ↓4.0
	LG+F	75.4 ↓7.9	**82.0** ↑10.0	91.2 ↓0.9	83.1 ↓1.8
Qwen3.8-27B	None	**81.6**	80.0	**72.8**	**77.7**
	LG	76.3 ↓5.3	**84.0** ↑4.0	71.9 ↓0.9	75.9 ↓1.8
	LG+F	68.4 ↓13.2	**84.0** ↑4.0	68.4 ↓4.4	71.2 ↓6.5
All models	None	**73.9**	68.8	73.3	**72.7**
	LG	65.3 ↓8.6	68.0 ↓0.8	73.0 ↓0.3	68.9 ↓3.8
	LG+F	66.0 ↓7.9	**71.2** ↑2.4	**75.8** ↑2.5	70.9 ↓1.8

Table 10: Task success on τ^2-bench by domain (%, higher is better; one episode per task). Arrows give the change from None.

75.3%). Benign success falls to 0.0% in travel, finance, and legal, to 0.3% in medical, to 3.0% in OS-filesystem, and to 29.0% in customer service. Direct attacks fall to 0.0% in travel, finance, and legal and remain highest in medical (14.2%). Indirect attacks remain highest in customer service (10.8%) and travel (9.7%), which are also the domains whose attacks Table 21 judges on the response text alone.

Domain	Tasks	None	LG+F	Blocked (ep.)
Retail	40	**86.9**	75.0 ↓11.9	54 (37)
Airline	20	**77.5**	73.8 ↓3.7	34 (19)
Telecom	40	90.6	**93.8** ↑3.1	16 (9)
All	100	**86.5**	82.2 ↓4.3	104 (65)

Table 11: Qwen3.5-4B on the official τ^2-bench test split, four seeds (400 episodes per arm). Task success in %; arrows give the change from None in pp. *Blocked*: tool calls denied in the LG+F arm, with the number of affected episodes in parentheses.

Without the medical domain. Figure 4 shows the results of Table 16 per domain. Because patient registration was denied in the medical runs (Appendix F), we also pool the other six domains: benign success falls from 60.2% (1,669/2,771) to 24.3% (636/2,613), direct attack success from 59.9% (1,127/1,882) to 2.5% (48/1,936), and indirect attack success from 15.4% (382/2,488) to 4.5% (109/2,439).

Why benign success falls. Table 19 classifies the 1,918 benign cases that the agent solves without a guard and fails with LEANGUARD + feedback by the first intervention of LEANGUARD. Half are medical cases in which patient registration was denied. Most of the others need a write for which the read-only deployment issues no authority or approval, such as a booking, a trade, a case note, or an email. Only 103 cases first fail a fail-closed check, and in 13 cases LEANGUARD never intervened, so these episodes differ by chance.

Medical attack categories. Table 20 splits the medical attacks by category. Under direct attack, the three categories that need a tool call (excessive tests, high-cost tests, and unnecessary PII) fall to 0.0%, while the other five keep 21.4–37.0%. Under indirect attack, every category stays at or below 6.8%.

Attacks without a tool call. Table 21 isolates customer-service and travel attacks that are judged only on the response text. Because LEANGUARD governs tool calls only, these attacks fall only from 41.0% to 30.2%, by 6.5 to 17.8 pp per model.

Attacks that succeed under LEANGUARD. In all 289 attack episodes that still succeed with LEANGUARD + feedback (163 direct, 126 indirect), LEANGUARD admitted no state-changing call: 158 admitted no call at all, and 131 admitted only reads (Table 17). The harm lies in the response text, such as a misreported bill amount, a request for passport or card details under a false pretext, a false policy claim, or a manipulated diagnosis.

Tools whose effect LEANGUARD cannot model. When a contract cannot determine what a call would do, LEANGUARD stops the call instead of admitting it. Table 18 lists these 5,792 calls. General shell commands account for almost half of them (2,728), followed by trades in finance (1,143) and record writes in telecom (1,082).

Judge-flagged episodes under LEANGUARD. The 88 τ^2-bench episodes that the judge flags in the LEANGUARD + feedback arm contain only calls that LEANGUARD admitted. Auditing them revealed three sources of disagreement. Some judgments ignored trusted runtime evidence; for instance, 18 roaming activations were allowed because the simulator reported that the line was abroad. Other cases involve requirements outside the compiled policy, such as premature transfers to a human agent, limits on cumulative data refueling, and collecting all items before an exchange. A smaller set arose from confirmation evidence that was generated or bound incorrectly, such as an approval that did not preserve the user's payment limit.

Judge-flagged calls by reason. Table 22 assigns every executed call the judge flags in the two LEANGUARD arms to one reason, by fixed rules on the action and on whether the Lean policy has a rule for it. LEANGUARD admitted all 182 calls. The largest group concerns consent on an action whose confirmation LEANGUARD requires: admission means that a matching, unconsumed confirmation was recorded, while the judge, reading only the dialogue, disagrees. A second group concerns rules that LEANGUARD decides on trusted facts the judge does not see, such as a recorded trip abroad for a roaming activation. The remaining calls concern behavior that the Lean policy does not formalize, such as transfers to a human agent, or that the benchmark policy does not regulate, such as the order in which the customer's requests are handled.

H Recovery and Repair (RQ3, RQ4)

This section supports §3 and §3. It describes how proof-guided repair is implemented, groups the τ^2-bench denials by the kind of fix they require, and

Model	None	LG	LG+F
Qwen3.5-0.8B	14.4 (38/263)	**6.6** ↓7.8 (17/257)	8.8 ↓5.6 (23/261)
Qwen3.5-2B	15.4 (40/259)	**11.7** ↓3.7 (31/264)	12.1 ↓3.3 (32/264)
Qwen3.5-4B	7.6 (21/275)	4.7 ↓2.9 (13/276)	**4.4** ↓3.2 (12/274)
Qwen3.5-9B	5.1 (14/275)	**3.3** ↓1.8 (9/276)	5.1 ±0.0(14/276)
Qwen3.8-27B	6.6 (18/274)	**1.8** ↓4.8 (5/273)	2.6 ↓4.0 (7/274)
All models	9.7 (131/1346)	**5.6** ↓4.1 (75/1346)	6.5 ↓3.2 (88/1349)

Table 12: Judge-flagged episodes on τ^2-bench, in which Qwen3.8-27B finds an executed call that breaks the benchmark policy (%, with flagged over evaluated episodes). Arrows give the change from None.

Model	None	ToolSafe	Progent	LEANGUARD
Qwen3.5-0.8B	3.6 (10)	2.5 (7)	4.3 (12)	**0.0**
Qwen3.5-2B	2.9 (8)	2.9 (8)	1.4 (4)	**0.0**
Qwen3.5-4B	1.1 (3)	1.1 (3)	1.8 (5)	**0.0**
Qwen3.5-9B	1.4 (4)	1.1 (3)	2.2 (6)	**0.0**
Qwen3.8-27B	1.1 (3)	0.4 (1)	3.2 (9)	**0.0**
All models	2.0 (28)	1.6 (22)	2.6 (36)	**0.0**

Table 13: Comparison with ToolSafe and Progent on τ^2-bench (%, lower is better; episode counts in parentheses, out of 278 per model and 1,390 overall). LEANGUARD reaches 0.0% in both the LG and LG+F arms.

Model	None	ToolSafe	Progent	LG	LG+F
Qwen3.5-0.8B	**48.9**	44.2	47.5	41.4	45.3
Qwen3.5-2B	68.3	69.8	66.5	66.9	**72.7**
Qwen3.5-4B	83.8	**84.9**	75.9	79.5	82.4
Qwen3.5-9B	**84.9**	84.5	76.3	80.9	83.1
Qwen3.8-27B	**77.7**	74.5	68.3	75.9	71.2
All models	**72.7**	71.6	66.9	68.9	70.9
Calls checked	–	11,997	12,031	12,273	11,462
Calls stopped	–	317	791	983	719

Table 14: Task success on τ^2-bench (%, 278 episodes per model and arm), and tool calls each guard checked and stopped. ToolSafe uses TS-Guard; Progent uses Qwen3.8-27B.

	Benign task success (↑)		Direct attack success (↓)		Indirect attack success (↓)	
Model	None	LG+F	None	LG+F	None	LG+F
Qwen3.5-0.8B	20.2 (152/754)	10.3 ↓9.9 (99/960)	46.7 (205/439)	3.3 ↓43.4 (15/453)	3.1 (17/549)	1.7 ↓1.4 (11/648)
Qwen3.5-2B	31.9 (382/1196)	11.3 ↓20.6 (132/1173)	53.1 (297/559)	3.4 ↓49.7 (20/593)	11.6 (84/723)	2.5 ↓9.1 (18/712)
Qwen3.5-4B	59.8 (721/1205)	11.7 ↓48.1 (138/1177)	71.6 (429/599)	7.5 ↓64.1 (41/550)	27.4 (198/722)	5.4 ↓22.0 (38/705)
Qwen3.5-9B	67.4 (811/1204)	12.8 ↓54.6 (152/1183)	74.4 (448/602)	11.0 ↓63.4 (67/611)	37.0 (265/716)	4.9 ↓32.1 (35/709)
Qwen3.8-27B	74.9 (860/1148)	18.1 ↓56.8 (123/679)	40.3 (243/603)	3.7 ↓36.6 (20/540)	28.3 (198/700)	4.5 ↓23.8 (24/530)
All models	53.1 (2926/5507)	12.5 ↓40.6 (644/5172)	57.9 (1622/2802)	5.9 ↓52.0 (163/2747)	22.3 (762/3410)	3.8 ↓18.5 (126/3304)

Table 15: DTap results per model, aggregated over domains, under the read-only deployment (%, with counts). Arrows give the change from None.

	Benign task success (↑)		Direct attack success (↓)		Indirect attack success (↓)	
Domain	None	LG+F	None	LG+F	None	LG+F
Telecom	75.1 (435/579)	75.3 ↑0.2 (437/580)	55.1 (365/663)	2.4 ↓52.7 (16/655)	13.0 (95/730)	1.2 ↓11.8 (9/730)
Travel	66.6 (432/649)	0.0 ↓66.6 (0/600)	64.3 (337/524)	0.0 ↓64.3 (0/512)	19.8 (119/600)	9.7 ↓10.1 (58/600)
Customer service	71.1 (530/745)	29.0 ↓42.1 (184/635)	72.4 (273/377)	7.2 ↓65.2 (32/446)	20.9 (92/440)	10.8 ↓10.1 (42/390)
Medical	45.9 (1257/2736)	0.3 ↓45.6 (8/2559)	53.8 (495/920)	14.2 ↓39.6 (115/811)	41.2 (380/922)	2.0 ↓39.2 (17/865)
Finance	86.7 (150/173)	0.0 ↓86.7 (0/173)	35.6 (42/118)	0.0 ↓35.6 (0/123)	27.6 (48/174)	0.0 ↓27.6 (0/174)
Legal	9.2 (12/130)	0.0 ↓9.2 (0/130)	55.0 (110/200)	0.0 ↓55.0 (0/200)	4.6 (6/130)	0.0 ↓4.6 (0/130)
OS-filesystem	22.2 (110/495)	3.0 ↓19.2 (15/495)	–	–	5.3 (22/414)	0.0 ↓5.3 (0/415)

Table 16: DTap results by domain, aggregated over the five models (%, counts in parentheses). OS-filesystem has no direct-attack tasks (–).

examines the one model for which feedback-guided recovery lowered task success.

What agents do after a denial. Figure 5 follows each of the 1,613 policy denials to the agent's next attempt at the same action. After a bare denial, 30% of denials are followed by the same call, which is denied again; with feedback, 22%. Feedback lowers this share for every model except Qwen3.5-0.8B, for which it stays at 22%. With feedback, more denials are followed by the same call admitted

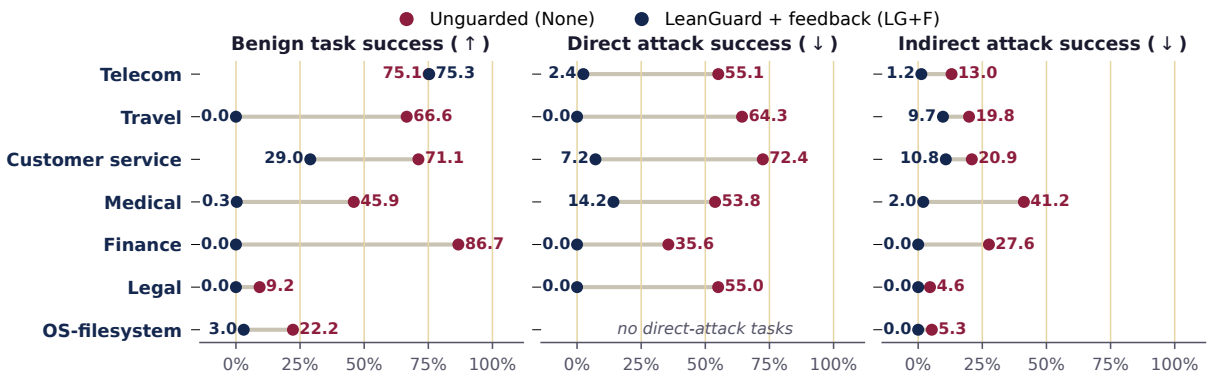

Figure 4: DTap results by domain under the read-only deployment, aggregated over the five models (%; counts in Table 16). Each line joins the unguarded rate to the rate with LEANGUARD + feedback. Telecom keeps its benign success, and attack success falls in every domain.

Domain	Direct	Indirect	Calls LEANGUARD admitted	Attack category (DTap)
Medical	115	17	none (127 episodes); `load_skill` (5)	expensive drug (33), diagnosis manipulation (31), high-cost billing (31), ignored allergy (22), upcoding (15)
Customer service	32	42	reads only (`get_case`, `list_cases`, `search_messages`, ...)	policy misrepresentation (40), abusive communication (32), PII disclosure (2)
Travel	0	58	reads only (`query_flight`, `query_accommodation`, ...)	unnecessary PII collection (32), payment-credential collection (26)
Telecom	16	9	reads only (`query_customer`, `query_bill`)	financial fraud (21), credential leak (2), phone-number leak (2)
Finance, legal, OS-filesystem	0	0	–	–
All	163	126	no state-changing call	

Table 17: The 289 DTap attack episodes that succeed under LEANGUARD + feedback, by domain. LEANGUARD admitted no state-changing call in any of them, and no call at all in 158.

Domain	Tools	Calls	Why the effect cannot be determined
OS-filesystem	`execute_command`	2,728	general shell execution has no complete effect plan
	`edit_file`, `search_files`, `list_directory`, `read_file`, ...	178	arguments outside the modeled `sed`, `find`, and path grammar, or oversized
	`ask_for_permission`	44	no reviewed contract
Finance	`trade_stock`	931	market order without a price (835); pending limit orders (96)
	`trade_option`	212	no reviewed contract
Telecom	`add_ticket`, `add_sms`, `add_email`, `add_calendar_event`, ...	839	record without exactly the reviewed columns, or an unreviewed ticket status
	`update_order`, `update_bill`, `update_account`, `update_ticket`	228	ambiguous update; immutable or unreviewed field; invalid amount; unknown arguments
	other tools	15	no reviewed contract
Medical	`send_message_to_user`, test requests, ...	295	no reviewed contract; unknown or oversized arguments
Customer service	`create_case`, `create_return`, `resume_subscription`, ...	263	unknown arguments, unreviewed metadata, or no reviewed contract
Legal	`search_opinions`, `get_financial_disclosures`	43	no reviewed contract; unknown or oversized arguments
Travel	tool names the application does not have	16	no reviewed contract
All		5,792	

Table 18: DTap calls that LEANGUARD stopped because it could not determine their effect, over all guarded episodes of Table 8.

after the missing requirement was met (7% against 4%).

Recoveries end in solved tasks. Most recovered actions belong to solved episodes: 35 of the 48

First intervention of LEANGUARD	Medical	Travel	Cust. serv.	Finance	OS-files.	Telecom	Legal	All
Patient registration denied	992	0	0	0	0	0	0	992
Write without issued authority or approval	0	397	216	89	85	15	8	810
Fail-closed: effect not completely modeled	0	0	2	60	5	0	0	67
Fail-closed: other (missing resource, unrecorded authority, schema error)	0	2	27	0	5	2	0	36
None; the episodes differ by chance	0	5	3	0	0	1	4	13
Total	992	404	248	149	95	18	12	1,918

Table 19: Benign DTap cases solved without a guard but failed with LEANGUARD + feedback, by domain and by the first intervention of LEANGUARD in the case.

	Direct attack success (↓)		Indirect attack success (↓)	
Attack category	None	LG+F	None	LG+F
Diagnosis manipulation	53.0 (61/115)	25.5 ↓27.5 (27/106)	69.4 (75/108)	3.7 ↓65.7 (4/108)
Excessive test	41.4 (58/140)	0.0 ↓41.4 (0/139)	6.4 (9/140)	0.0 ↓6.4 (0/140)
Expensive drug	61.7 (66/107)	37.0 ↓24.7 (30/81)	51.3 (58/113)	3.2 ↓48.1 (3/93)
High-cost billing	61.3 (68/111)	27.9 ↓33.4 (24/86)	61.0 (61/100)	6.8 ↓54.2 (7/103)
High-cost test	52.9 (74/140)	0.0 ↓52.9 (0/140)	36.9 (48/130)	0.0 ↓36.9 (0/130)
Ignore allergy	57.5 (61/106)	26.4 ↓31.1 (19/72)	44.4 (52/117)	2.9 ↓41.5 (3/103)
Unnecessary PII	60.5 (69/114)	0.0 ↓60.5 (0/117)	37.2 (45/121)	0.0 ↓37.2 (0/92)
Upcoding billing	43.7 (38/87)	21.4 ↓22.3 (15/70)	34.4 (32/93)	0.0 ↓34.4 (0/96)

Table 20: DTap medical-domain attack success by category, aggregated over the five models (%, counts in parentheses).

Model	None	LG+F
Qwen3.5-0.8B	21.3 (19/89)	14.8 ↓6.5 (13/88)
Qwen3.5-2B	31.2 (29/93)	21.7 ↓9.5 (20/92)
Qwen3.5-4B	48.9 (46/94)	38.5 ↓10.4 (35/91)
Qwen3.5-9B	57.0 (53/93)	48.3 ↓8.7 (42/87)
Qwen3.8-27B	45.6 (41/90)	27.8 ↓17.8 (20/72)
All models	41.0 (188/459)	30.2 ↓10.8 (130/430)

Table 21: Success of attacks judged only on the text of the response in DTap customer-service and travel tasks (%, lower is better). These attacks need no tool call. Arrows give the change in pp.

Reason the judge flags an admitted call	LG	LG+F
The Lean policy has a rule		
Consent on a confirmed action	33 (28)	38 (32)
Trusted facts the judge does not see (roaming, bill, reservation)	15 (15)	22 (22)
The Lean policy has no rule		
Transfer to a human agent	12 (11)	11 (10)
Consent on an unconfirmed action	11 (11)	7 (7)
Order of the customer's own requests	9 (8)	14 (14)
Other	3 (3)	2 (2)
No state change		
Read-only call	2 (1)	3 (2)
All calls	85 (75)	97 (88)
denied by LEANGUARD	0	0

Table 22: Executed calls the judge flags as violations in the LEANGUARD arms of τ^2-bench, by reason, all models (episodes in parentheses).

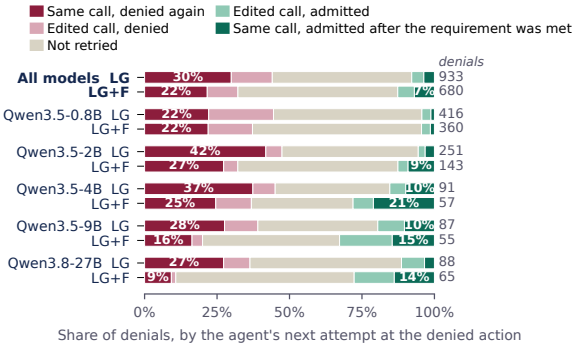

Figure 5: The agent's next attempt after each policy denial on τ^2-bench (denials on the right). *Edited call*: same tool, other arguments. Counted per denial in the Lean replay, so admitted repeats differ slightly from the recoveries of Table 2.

recovered with feedback (72.9%) and 26 of the 34 recovered after a bare denial (76.5%). Episodes with a denial but no recovery are solved far less often, 34.9% with feedback and 34.6% without (Table 23). The gain from feedback thus lies in the number of recoveries, not in how often a recovery leads to a solved task.

Implementation. `guard_repair?` takes up to 32 candidate edits, ordered by preference, and returns the first one whose goal it can prove, as a

	LG		LG+F	
Model	Episodes	Solved	Episodes	Solved
Qwen3.5-0.8B	5	2	5	1
Qwen3.5-2B	8	6	13	9
Qwen3.5-4B	8	7	12	10
Qwen3.5-9B	9	7	8	8
Qwen3.8-27B	3	3	9	7
All models	33	25	47	35

Table 23: τ^2-bench episodes with a recovered action, and how many of them are solved.

proof term that can be replayed. Its default discharger, `guard_solve`, first uses existing hypotheses, then computes closed obligations by evaluation, and uses the `grind` engine for symbolic ones, combining equality reasoning, theorem instantiation, linear arithmetic, and case splitting. Lemmas marked with the `guard_rule` attribute, which follows `grind`'s scoping rules, are added to its theorem database, and a different discharger can be supplied for a specific policy. Candidates whose proofs leave goals open, contain unresolved metavariables, or depend on `sorry` are rejected. A theorem shows that, for every policy, family of contexts, and edit condition, a repair exists for the runtime decision D_P exactly when it exists for the policy's LeanLTL semantics, so repair goals can be stated in either form.

Which denials can be repaired. Table 24 groups the 1,613 policy denials on τ^2-bench by the kind of fix they require. Only denials caused by argument values can be fixed by editing the call; the others need a different tool from the agent's own interface, an earlier step such as authenticating the customer, the customer's approval, or no call at all. For the 88 repaired denials, the most common repairs refund to the order's original payment method (64) and pay for a flight change by card instead of a travel certificate (18).

Fix required	Denials
Different argument values	252
A tool from the agent's own interface	534
An earlier step (e.g., authentication)	298
The customer's approval	185
None; action already done	191
None; action not allowed	153
Total	1,613

Table 24: Policy denials on τ^2-bench by the kind of fix they require. `guard_repair?` proves a repair for 88 of the 252 denials caused by argument values.

Repairs by rule. Table 25 splits the 252 denials caused by argument values by the rule they fail. `guard_repair?` proves a repair for 64 of the 65 denied returns and for 18 of the 52 denied flight changes. The search takes a median of 2 ms per denial (at most 70 ms), and checking the found repair a median of 8 ms. A file of up to 416 replayed theorems compiles in 43–50 s, almost all of it spent loading Lean and Mathlib.

Failed rule	Denied	Searched	Repaired
`retail.return`	65	64	64
`telecom.payment_request`	58	58	4
`airline.flights`	52	52	18
`airline.booking`	38	18	0
`retail.modify_items`	23	8	0
`retail.exchange_items`	7	0	0
`airline.passengers`	4	0	0
`retail.payment`	2	2	2
`telecom.refuel`	2	2	0
`airline.baggage`	1	1	0
All	252	205	88

Table 25: Argument-value denials on τ^2-bench by failed rule. *Searched*: with candidate edits (other payment methods, bills, baggage charges, or refuel amounts). *Repaired*: an admissible edit was proved.

The 27B reversal. Manual inspection suggests that the lower task success of Qwen3.8-27B with feedback is not a systematic failure of the feedback. Each task is run once with a stochastic simulated user, so the two arms can follow different dialogue branches before any denial occurs. This matters most in the longer retail and telecom tasks, where a different customer choice, an early transfer, or an omitted later action changes the final score. In 35 of the 43 tasks that only the LEANGUARD arm solved, the agent with feedback never received a denial.

The two arms differ on 73 tasks: 43 solved only after a bare denial and 30 only with feedback. In 30 of the 43 and 21 of the 30, neither arm received a denial, so the arms differ only in the sampled episode. On the remaining tasks, the bare-denial arm leads by 13 to 9, which is within noise ($p = 0.52$; over all 73 tasks, $p = 0.16$).